Audit de sécurité Wi-Fi en laboratoire

WPA2 WPA3 et simulation Evil Twin

Présentation du projet par Otmane Arajdal | PFA de 4e année | Ingénierie des Réseaux et Cybersécurité | 2025-2026

J’ai participé à ce projet de fin d’année pour comprendre les échanges d’authentification Wi-Fi et la portée des tests offensifs. Le travail documente trois essais : WPA2-PSK, WPA3-SAE et un point d’accès jumeau. Cette synthèse présente les observations du rapport dans leur contexte expérimental, sans nouvelle exécution de tests.

Environnement et architecture

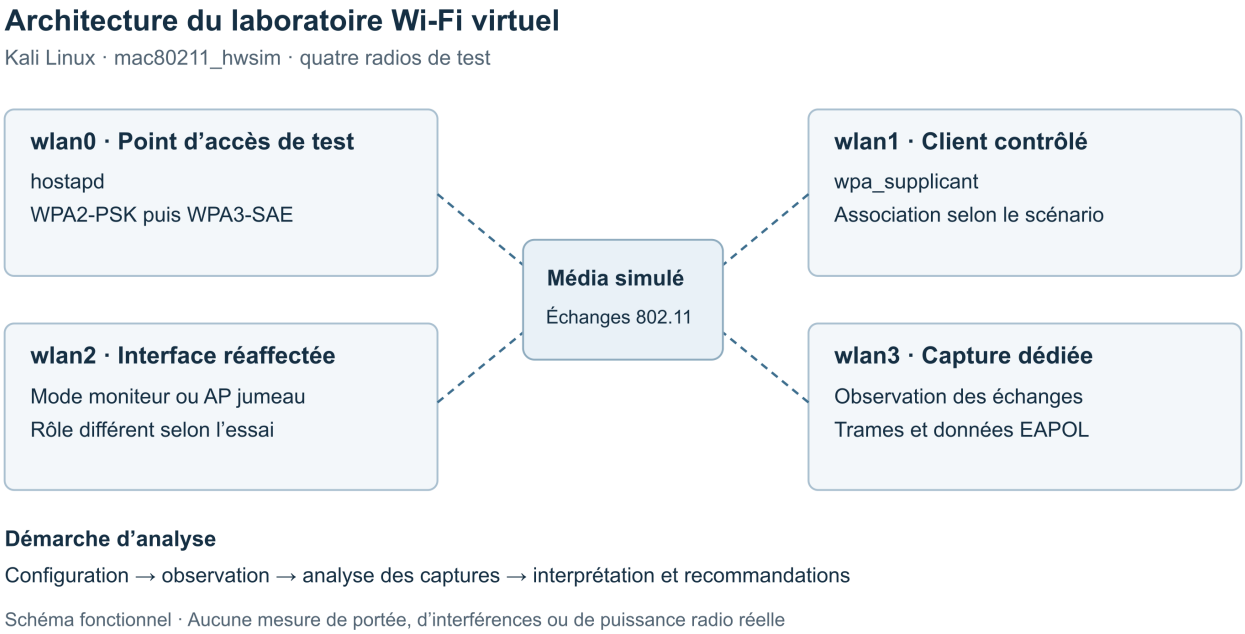


Figure 1 Schéma logique des quatre interfaces virtuelles. Les rôles de surveillance et du jumeau varient selon le scénario.

Outils	Fonction dans le projet
Kali Linux et mac80211_hwsim	Création du laboratoire et des radios virtuelles
hostapd et wpa_supplicant	Point d’accès et association du client contrôlé
Aircrack-ng	Observation des échanges et essais d’injection
hcxpcapngtool et Hashcat	Analyse des captures et vérification de candidats WPA2

Périmètre de l’étude

Les essais concernent le réseau virtuel de test, avec un secret WPA2 volontairement faible. Aucun test matériel sur un réseau tiers n’est rapporté. Le simulateur permet d’étudier les échanges sans reproduire la portée, les interférences ou la puissance d’un équipement radio réel.

Résultats et interprétation des essais



Figure 2 Tableau visuel des observations ; les valeurs de temps ne sont pas reprises comme un benchmark.

WPA2 et secret de démonstration

Le rapport documente une capture EAPOL, la conversion d'une paire exploitable et la récupération du secret de test par dictionnaire. Le résultat est lié à la faiblesse du secret choisi et à sa présence parmi les candidats. Il ne démontre pas une rupture d'AES ni une compromission rapide de tous les réseaux WPA2.

WPA3 et qualité de la capture

Le même traitement ne produit pas de hash exploitable dans l'essai WPA3. Cependant, le convertisseur annonce seulement quatre paquets et des trames essentielles manquantes. La configuration prévoit SAE et PMF obligatoire, mais cette capture ne constitue pas une comparaison cryptographique concluante ni une validation complète du blocage des désauthentifications.

Evil Twin et association contrôlée

Deux points d'accès portent le même SSID avec des BSSID distincts. Le client est dirigé vers le jumeau par son profil, et le jumeau utilise déjà le secret connu du laboratoire. La capture et la récupération reproduites sont des résultats sous ces conditions. Aucun choix spontané fondé sur le signal ni interception complète du trafic n'est validé.

Recommandations et retour d’expérience

Axe	Mesure proposée
Authentification	Privilégier WPA3-SAE lorsque les équipements le permettent ; examiner les modes de transition.
Trames de gestion	Configurer PMF selon le protocole et vérifier son comportement par un essai distinct.
Secret partagé	Si WPA2 reste nécessaire, utiliser un secret unique à forte entropie et éviter les candidats courants.
Équipements	Mettre à jour les logiciels et désactiver les fonctions WPS inutilisées.
Confiance et supervision	En entreprise, étudier des profils EAP-TLS gérés avec validation stricte des certificats et surveiller les AP inattendus.

Limites méthodologiques

La valeur 0 ACK apparaît dans les tests simulés. Elle ne suffit pas à prouver une désauthentification réussie ni son blocage par PMF. Le scénario jumeau impose l’association et ne mesure pas le comportement radio d’un client réel. Les captures ne permettent pas non plus un benchmark fiable : les durées et débits cités dans le rapport ne sont pas cohérents entre eux.

Les attaques PMKID, Dragonblood et WPS/Pixie-Dust sont des sujets étudiés ou envisagés. Aucun résultat pratique supplémentaire n’est revendiqué dans cette présentation. Une suite utile serait de conserver des captures complètes, vérifier chaque scénario séparément puis travailler sur un banc matériel contrôlé.

Bilan personnel

Ce PFA m’a permis de relier la configuration d’un réseau Wi-Fi à ses échanges d’authentification et aux données qu’un outil peut analyser. Il m’a surtout appris à distinguer un résultat de test de son interprétation : une clé retrouvée dans un cas préparé, un fichier vide et un client dirigé vers un AP ne prouvent pas la même chose. Cette lecture des preuves aide à formuler des recommandations proportionnées.

Documentation publique

Le dossier GitHub contient un README, les scénarios, l’analyse des résultats et leur traçabilité. Les visuels sont des schémas et des tableaux de synthèse ; les captures intégrales, les noms de comptes et les secrets de test ne sont pas redistribués. La synthèse est distincte du rapport original.

Références : Linux Wireless ; Hashcat ; travaux Dragonblood. Source expérimentale : rapport de PFA et figures originales ; positions des pages détaillées dans docs/sources-et-preuves.md.